Perspectives on Data Breach Laws

Aesha Shah

***Abstract*— This paper analyzes the Oklahoma and California data breach notification laws to determine the ideal legislative update for Georgia. It recommends a hybrid framework that balances consumer protection and economic viability.**

***Index Terms*— data breach notification, consumer protection, cybersecurity policy, economic viability, risk of harm**

I. Oklahoma

Director Moderate, the Oklahoma model represents a sensible, risk-based evolution of data privacy that balances consumer safety with business viability. It is tempting to look at the massive data privacy mechanisms in California and assume that "more is better." However, this approach restrains the economic reality of Georgia. We must confront a hard truth: while Georgia's current law from 2007 is quite outdated, overcorrecting with burdensome compliance would suffocate the economic growth we seek to protect. The economic stakes are severe; without a balanced framework, the ripple effect of these costs could sink small companies that lack the vast resources of global corporations [1].

The primary reason to adopt the Oklahoma statute (24 O.S. § 161 et seq.) is its “risk of harm” trigger [2]. Unlike broader mandates, Oklahoma defines a security breach not just by unauthorized access, but by the likelihood of damage. Specifically, notification is required when unauthorized access "causes, or the Entity reasonably believes has caused or will cause, identity theft or other fraud" to a resident [2]. This is a crucial distinction. It prevents the phenomenon of "notification fatigue," where consumers are bombarded with letters for minor incidents that pose no real threat, eventually leading them to ignore serious warnings. Research indicates that the most frequent consumer response to a data breach notification is to simply ignore it and do nothing [3]. By reserving notifications for truly risky events, we ensure that when a Georgian receives a letter, they know it requires immediate action [4].

From an economic standpoint, this standard is pertinent for Georgia's small and mid-sized businesses. Under the Oklahoma model, if a business can determine that a breach is unlikely to result in fraud (perhaps because the data was effectively encrypted or the intruder was an employee acting in good faith) they are not forced to incur the significant costs of a mass mailing [2]. If we were to adopt a stricter liability model, we would force Georgia companies to allocate excessive resources to compliance rather than innovation, a trade-off that harms our local economy. The average cost of a data breach in the U.S. has already surged to over $9.36 million in 2024 [5]. And, strict regulatory fines and post-breach response costs are significantly inflating breach expenses [5].

Furthermore, the Oklahoma definition of "Personal Information" updates our archaic 2007 standard [6] without overreaching. Our current Georgia law focuses narrowly on Social Security numbers (SSNs) and financial account numbers. The Oklahoma statute modernizes this by adding "biometric data," such as fingerprints or retina images [2]. This brings Georgia out of its old standards (which do not include sufficient protection of personal information) into the 21st century regarding authentication. As biometric systems are increasingly prone to spoofing and presentation attacks, legal protection for this data is essential for modern security [7]. This immutable data is far more dangerous if stolen than a changeable password [8].

Finally, regarding cybersecurity incentives, the Oklahoma model provides a "safe harbor" of sorts. It

explicitly states that entities are not liable for civil penalties if they use "reasonable safeguards" and provide the required notice [2]. This creates a powerful incentive structure like successful safe harbor laws in Ohio and Utah, which offer legal shields to companies that proactively implement written cybersecurity programs [9]. The penalties themselves are capped at $150,000 for a series of breaches [2]. This creates a clear incentive: invest in reasonable security and be transparent when fraud is likely, and you will not be destroyed by fines.

II. California

Director Moderate, having reviewed the arguments for the Oklahoma model, I must respectfully disagree with the premise that a "risk of harm" trigger is sufficient for modern data security. The intent of the Oklahoma model is clear (to spare businesses) but the implementation risks leaving Georgia residents vulnerable to the worst types of digital crime. I encourage the Task Force to look toward the California model (Civ. Code § 1798.82) as the true *gold standard* for consumer protection [10].

The glaring weakness of the Oklahoma approach is that it allows the breached entity to decide if a consumer is at risk. By contrast, California mandates notification immediately (within 30 calendar days of discovery) if unencrypted personal information was acquired, or reasonably believed to have been acquired, by an unauthorized person [10]. This removes the conflict of interest where a company might downplay a breach to save face or money. When people understand that their data is exposed, regardless of the company's opinion on the matter, they are more likely to take proactive steps to lock their credit. Studies show that concern about identity theft nearly doubles among consumers following a breach notification [3].

Moreover, the California definition of *Personal Information* covers the actual threats facing Georgians today. The Oklahoma proposal ignores a massive environment for fraud: online accounts (and the credentials we use to sign up for and login to these accounts) [2]. California law explicitly covers a “username or email address in combination with a password or security question” [10]. In 2025, credential-based attacks increased by 6% compared to the previous year, making them a primary vector for digital crime [11]. In an era of "credential stuffing" attacks, where hackers use stolen logins to drain bank accounts or steal identities, failing to cover email credentials is a significant legislative failure. With 22% of all data breaches now beginning with stolen credentials [11], adopting the California standard would force Georgia companies to secure these digital keys properly.

Additionally, California prioritizes the "help" aspect of notification. It is not enough to simply tell a consumer “We lost your data." The California statute requires that if SSNs or driver's licenses are exposed, the entity must offer credit monitoring services at no cost for not less than 12 months [10]. Mandating professional monitoring helps mitigate financial impact and reputational damage. It also mandates that the notification letter use plain language headings like "What Happened" and "What You Can Do". Transparency requires that communication be easy to understand; otherwise, dense legal jargon effectively hides the risk from the consumer [12]. This standard transforms the notification from a legal disclaimer into a functional tool for consumer safety.

While the previous essay argued that California's scope is too broad, the inclusion of "medical information" and "health insurance information" is critical [10]. Our current Georgia law leaves these sensitive records exposed. Healthcare breaches remain the costliest type of data breach, averaging $12.2 million per incident in 2025 [1]. If we are to truly protect the privacy of our citizens, we cannot allow a patchwork law that protects a credit card number but ignores a diagnosis history. Breaches of confidentiality can cause significant stigma, embarrassment, and economic harm [13]. The California model puts regulated entities on notice that all sensitive data deserves protection.

III. Author’s Recommendation for Georgia

Director Moderate, after evaluating the legislative landscapes of Oklahoma and California, it is my

opinion that neither statute should be adopted entirely to replace Georgia's current law. However, relying solely on our 2007 statute is no longer viable; it leaves Georgians exposed to modern threats like biometric theft and credential stuffing.

Therefore, I recommend amending Georgia law to create a “best of both worlds” hybrid statute. This approach respects our state's conservative regulatory philosophy (punishing actual harm rather than technicalities) while closing critical security gaps.

(a) Replace Georgia's current notification standard with Oklahoma's risk-based trigger. Notifications should only be required if unauthorized access "has caused or will cause, identity theft or other fraud" [2]. This prevents "notification fatigue" for consumers and protects small businesses from the high costs of reporting harmless incidents.

(b) Update Georgia's definition of *Personal Information* to include a "username or email address in combination with a password or security question and answer that would permit access to an online account" [10]. As noted in my second essay, stolen credentials are a primary entry point for modern digital crime.

(c) Also update Georgia’s definition of *Personal Information* to include "biometric data," such as fingerprints or retina images [2]. This future-proofs our statute against emerging identity theft trends involving physical characteristics.

(d) Incentivize proactive security rather than just reactive punishment, we should adopt the Oklahoma provision that exempts entities from civil penalties if they maintain "reasonable safeguards" and comply with notification requirements [2].

If the Task Force is required to choose strictly between the two models as written, I recommend you vote for the Oklahoma approach.

The California model, while comprehensive, is too blunt for Georgia’s economy. Its strict liability and broad mandates would likely stunt local business innovation. The Oklahoma statute represents a substantial and necessary improvement over our current law by covering relevant personal information and establishing a clear penalty structure. It effectively updates our standards to the 21st century without crossing the line into overregulation.

APPENDIX

I have complied with the generative AI policy of this course.

REFERENCES

[1] “The Economic Impact of Data Breaches in 2025.” OpenCart, November 18 2025. [Online]. Available: https://www.opencart.com/blog/the-economic-impact-of-data-breaches-in-2025

[2] Oklahoma Data Breach Notification Law

[3] “Consumer Study on Aftermath of a Breach.” Ponemon, April 2014. [Online]. Available: https://www.ponemon.org/local/upload/file/Consumer%20Study%20on%20Aftermath%20of%20a%20Breach%20FINAL%202.pdf

[4] T. Krantz and A. Jonker, “What Is Alert Fatigue?” IBM, May 29 2025. [Online]. Available: https://www.ibm.com/think/topics/alert-fatigue

[5] “Cost of a Data Breach Report 2024.” IBM. July 2024. [Online]. Available: https://wp.table.media/wp-content/uploads/2024/07/30132828/Cost-of-a-Data-Breach-Report-2024.pdf

[6] Georgia Data Breach Notification Law

[7] “Biometrics and Privacy – Issues and Challenges”. Office of the Victorian Information Commissioner. July 2019. [Online]. Available: https://ovic.vic.gov.au/privacy/resources-for-organisations/biometrics-and-privacy-issues-and-challenges/

[8] K. Chin, “The Future of Biometric Data Protection: Securing Data Privacy” UpGuard, December 1 2025. [Online]. Available: https://www.upguard.com/blog/the-future-of-biometric-data-protection

[9] J. Köller, “US Cybersecurity Safe Harbor Laws by State: All Current Legislation,” tenfold Security. December 1 2025. [Online]. Available: https://www.tenfold-security.com/en/cybersecurity-safe-harbor-laws/

[10] California Data Breach Notification Law

[11] M. Khalil, “Compromised Credential Statistics 2025: Costs, Trends, Defenses,” DeepStrike. December 18 2025. [Online]. Available: https://deepstrike.io/blog/compromised-credential-statistics-2025

[12] F. McGovern, “The GDPR & Plain Language – What You Need To Do To Comply.” September 14 2017 [Online]. Available: https://www.visiblethread.com/blog/the-gdpr-and-plain-language-how-to-be-compliant/

[13] S. J. Nass, L. A. Levit, and L. O. Gostin, “The Value and Importance of Health Information Privacy,” in *Beyond the HIPAA Privacy Rule: Enhancing Privacy, Improving Health Through Research*, National Academies Press (US), 2009. [Online]. Available: https://www.ncbi.nlm.nih.gov/books/NBK9579/